

SECURITY REVIEW

FOR PULSE IN PRIVATE



PREPARED FOR

Pulse In Private

PREPARED BY

Kann Audits

DATE REPORTED

3 April 2025

INSIDE THIS REPORT

CONTENTS

01	AUDIT SUMMARY	03
02	SCOPE	04
03	AUDITORS	05
04	METHODOLOGY	06
05	RISK CLASSIFICATION	07
06	FINDINGS SUMMARY	08
07	DETAILED FINDINGS	09
	I-01 Add Off-Chain Checks for requestWithdraw to Prevent Spam with Invalid Proofs and Potential Gas Waste for Relayers	09
	I-02 Add an On-Chain View Function for Relayers to Estimate Exact Fee Rewards	10
08	DISCLAIMER	11
09	ABOUT KANN AUDITS	12

01 - OVERVIEW

AUDIT SUMMARY

Pulse In Private engaged Kann Audits to perform a security review of the Pulse In Private smart contracts. A team of 2 security researchers performed a manual review of the in-scope contracts. All findings identified during the assessment are documented in this report.

TOTAL FINDINGS

2

 ISSUES

CRITICAL	-
HIGH	-
MEDIUM	-
LOW	-
INFORMATIONAL	02

ENGAGEMENT DETAILS

PREPARED FOR	Pulse In Private
PREPARED BY	Kann Audits
DATE REPORTED	3 April 2025
METHODS	Manual review

02 - WHAT WE REVIEWED

SCOPE

REPOSITORY	https://github.com/alexbabits/pip
AUDITED COMMIT	b7234af

#	FILE
01	/src/Pip.sol
02	/circuits/height12/withdraw.circom

03 - THE TEAM ON THIS ENGAGEMENT

AUDITORS

KA

Kann

LEAD SECURITY RESEARCHER

IV

Ivan Fitro

LEAD SECURITY RESEARCHER

METHODOLOGY

An engagement with Kann Audits involves a team of security researchers performing independent reviews of the codebase at the start of the engagement, followed by collaborative review sessions where auditors share findings and explore additional attack vectors to improve overall coverage.

The review included a line-by-line manual inspection of the in-scope codebase, along with analysis of the protocol architecture, access control mechanisms and state transitions. The team also assessed the code against common smart contract security best practices and industry standards.

STEP BY STEP

OUR SECURITY PROCESS

01

Kickoff & Context

A kickoff call to understand architecture, trust boundaries, threat assumptions and intended behaviour.

02

Scope & Preparation

Confirm the commit, files in scope, dependencies and the riskiest areas. We open a private channel between your team and our auditors.

03

AI First Scan

Kann AI, our proprietary model built to find security bugs, scans the codebase before the manual review starts.

04

Expert Security Review

Line-by-line analysis of exploit paths, invariant breaks, edge cases, accounting and integration risks.

05

Findings & Proofs

Each issue is confirmed, rated and backed by a proof of concept or a precise reproduction path.

06

Mitigation Review

We review every fix, confirm it resolves the root cause and flag partial or incorrect mitigations.

COVERAGE

THE REVIEW SPECIFICALLY CONSIDERED

- ✓ Testing against common and uncommon attack vectors
- ✓ Contract logic matching the client's intended behaviour
- ✓ Manual line-by-line review by experienced auditors
- ✓ Architecture and design analysis for secure component interactions and clear trust boundaries
- ✓ Compliance with industry best practices and known smart contract security standards
- ✓ Cross-referencing patterns with industry-standard implementations
- ✓ Access control verification
- ✓ State transitions and logic, to detect inconsistencies, unexpected behaviour or exploitation paths

RISK CLASSIFICATION

Severity combines the **impact** of an issue if exploited with the **likelihood** that the conditions for exploitation are met.

● CRITICAL	Directly exploitable with few or no preconditions, leading to theft or permanent loss of funds or loss of control of the system. Must be fixed before deployment.
● HIGH	Directly exploitable vulnerabilities that can lead to significant material loss or critical impact on the system and require immediate fixing.
● MEDIUM	Moderate loss of funds or impact on multiple users, but only under specific conditions. Exploitable without privileged access, but typically requires certain assumptions or edge cases.
● LOW	Issues with limited impact that do not put funds directly at risk, such as edge cases or deviations from documented behaviour.
● INFORMATIONAL	Non-exploitable findings such as best-practice deviations, cosmetic issues or documentation and compliance notes. They do not need urgent remediation but improve code quality and maintainability.

06 - ALL ISSUES

FINDINGS SUMMARY

● CRITICAL —	● HIGH —	● MEDIUM —	● LOW —	● INFO 02
TOTAL 02 FIXED 02 ACKNOWLEDGED 00				

ID	TITLE	SEVERITY	STATUS
I-01	Add Off-Chain Checks for requestWithdraw to Prevent Spam with Invalid Proofs and Potential Gas Waste for Relayers	● INFORMATIONAL	● FIXED
I-02	Add an On-Chain View Function for Relayers to Estimate Exact Fee Rewards	● INFORMATIONAL	● FIXED

DETAILED FINDINGS

I-01

Add Off-Chain Checks for requestWithdraw to Prevent Spam with Invalid Proofs and Potential Gas Waste for Relayers

SEVERITY

● INFORMATIONAL

STATUS

● FIXED

■ DESCRIPTION

In the requestWithdraw process, users submit a withdrawal request by providing a proof and public signals which get sent in a Telegram group. Relayers monitor this group and use the provided information to call the on-chain withdraw function.

However, without proper off-chain validation, bad actors can flood the Telegram group with invalid or duplicate requests, causing relayers to waste gas attempting failed transactions.

■ RECOMMENDATION

To prevent this, off-chain validation should include:

Nullifier Existence – Ensuring the provided nullifier corresponds to a valid deposit.

Correct Recipient – Verifying that the recipient address matches the expected one for the nullifier.

Withdrawal Status – Checking if the nullifier has already been used for a withdrawal.

■ REMEDIATION

● FIXED

I-02

Add an On-Chain View Function for Relayers to Estimate Exact Fee Rewards

SEVERITY

● INFORMATIONAL

STATUS

● FIXED

■ DESCRIPTION

Currently, relayers calling the withdraw function lack an efficient way to determine the exact fee they will receive for processing a withdrawal. This uncertainty may discourage participation or lead to inefficient relaying strategies.

■ RECOMMENDATION

To address this, an on-chain view function should be implemented to allow relayers to see the exact fee amount they will receive before executing a withdrawal transaction.

■ REMEDIATION

● FIXED

08 - PLEASE READ

DISCLAIMER

A security audit can never guarantee the complete absence of vulnerabilities. Audits are a time, resource and expertise-bound effort in which we aim to identify as many issues as possible.

This review covers only the files listed in the Scope section at the audited commit. Code changed after that commit, external dependencies, deployment configuration and operational practices may introduce additional risk.

ABOUT KANN AUDITS

Kann Audits is a Web3 security audit company helping DeFi protocols, blockchain networks, and infrastructure teams build securely at every stage, from development to launch and beyond.



EXPERT SECURITY AUDITS

Human-led smart contract security audits built around the architecture, business logic, integrations and risk profile of complex Web3 protocols.



AI SECURITY SCAN

Kann AI extracts Solidity call graphs and returns function-level security signals for expert validation.



FORMAL VERIFICATION

Define security properties for critical protocol behaviour and evaluate whether the implementation satisfies those specifications.



INCIDENT RESPONSE

A direct triage path for suspected exploits, critical vulnerabilities, suspicious transactions and urgent remediation review.



KANN AUDITS
WEB3 SECURITY AUDITS

GET IN TOUCH

WEBSITE	kannaudits.com
PORTFOLIO	github.com/KannAudits
EMAIL	contact@kannaudits.com
X	@KannAudits
TELEGRAM	@KannAudits